

Siber Güvenliğe Giriş

Hafta 1

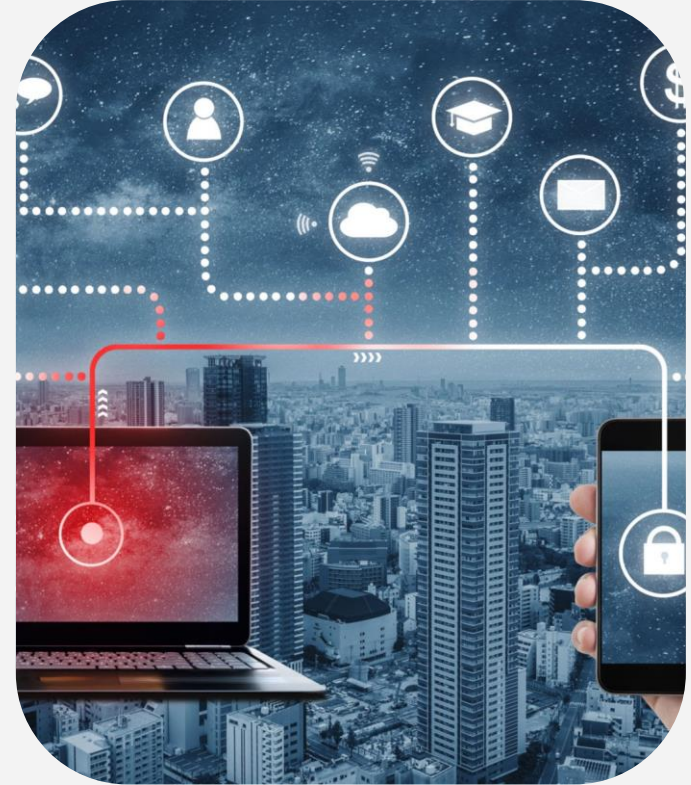
Siber Güvenliğe Giriş: Temel Kavramlar ve Yöntemler

Siber güvenlik alanına hoş geldiniz. Bu sunumda, dijital dünyada karşılaştığımız güvenlik tehditlerini, bu tehditlerle mücadele yöntemlerini, etik ve yasal çerçeveleri, zararlı yazılım türlerini ve siber güvenlik profesyonellerinin kritik rollerini detaylı bir şekilde inceleyeceğiz. Günümüzde bilgisayar bilimi ve teknolojinin hızla gelişimi, internetin ve sosyal ağların yaygınlaşması, mobil ve IoT cihazlarının artışı ile güvenlik kavramı her zamankinden daha önemli hale gelmiştir.



Siber Güvenliğin Artan Önemi

İnsanoğlunun en temel ihtiyaçlarından biri olan güvenlik kavramı, günümüzde dijitalleşen dünyada daha da kritik bir rol oynamaktadır. Devletler, kurumlar ve bireyler, kamu hizmetlerinden bankacılık işlemlerine, şirket toplantılarından ticarete ve eğitime kadar birçok faaliyeti elektronik ortamlar üzerinden yürütmektedir. Bu durum, güvenlik riskini önemli ölçüde artırmıştır. Bilişim, ağ ve IoT cihazların, web ve mobil uygulamaların, verilerin saldırganlara karşı korunması için verilen çaba, siber güvenlik (cyber security) kavramı ile ifade edilmektedir



Dijital Dünyadaki Temel Güvenlik Tehditleri

Dijital dünyada güvenliğı tehdit eden başlıca unsurlar bulunmaktadır. Bu unsurlar, bilgisayar korsanları (hackerlar) ve zararlı yazılımlardır. Güvenlik profesyonelleri, bu tehditlere karşı koymak için çeşitli stratejiler ve teknolojiler geliştirir. Siber güvenlik, bilgi teknolojilerinin kullanıldığı dijital ortamlarda bilişim sistemlerini, ağıları ve verileri koruma, tehditlere karşı güvenliğı sağlama sürecini içerir. Bu süreç, dijital dünyada bilinçli ve güvende olmayı hedefler



Hacker ve Hacking Kavramlarının Kökeni

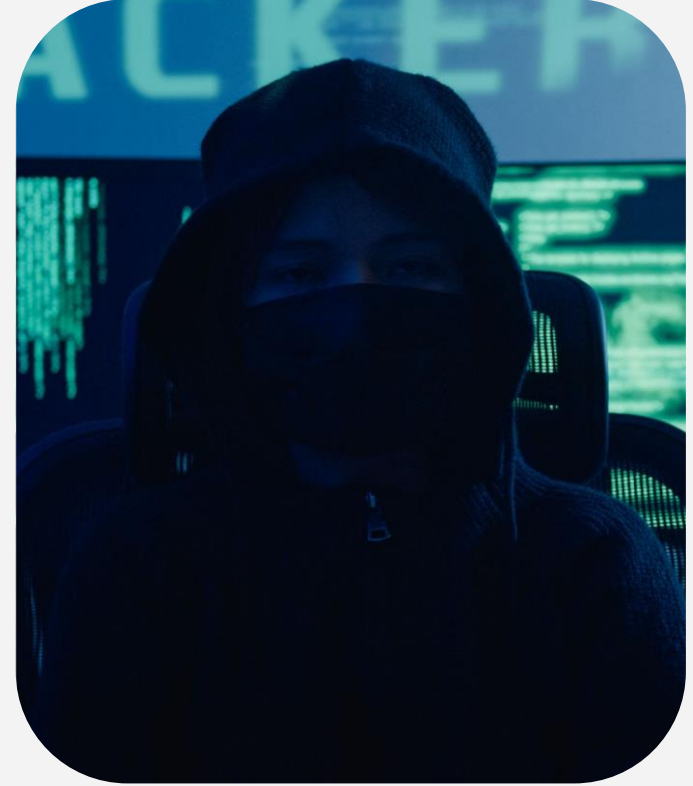
Hacker kavramı, ilk defa 1960'lı yıllarda bilgisayar donanım ve yazılımlarını kurcalayan, değiştiren ve geliştiren kişiler olarak ortaya atılmıştır. Başlangıçta olumlu bir anlam taşısa da, bu kavram zamanla suç teşkil eden eylemleri de içine almıştır. Türk Dil Kurumu Güncel Türkçe Sözlük, bilgisayar korsanını "Bilgisayar ve haberleşme teknolojileri konusundaki bilgisini gizli verilere ulaşmak, ağlar üzerinde yasal olmayan zarar verici işler yapmak için kullanan kimse" olarak tanımlamıştır. Hackleme (Hacking) kavramı ise ilk başlarda elektronik sistemlerin farklı yöntemlerle değiştirilerek kullanılması anlamını taşımıştır. Zamanla bu anlamından sıyrılarak bilgisayar, mobil, IoT cihaz ve ağ sistemlerine zararlı yazılım bulaştırmak, yasa dışı amaçlarla izinsiz erişim sağlamak ve yetkisiz erişilen sistemde değişiklik yapmak eylemlerine dönüşmüştür



Hacker ve Hacking Kavramlarının Kökeni

Hackerların Özellikleri ve Yetenekleri İçerik:
Hackerlar, sistem, ağ ve programlama alanlarında üst düzey teknik bilgi ve beceriye sahiptir. Bilgisayar korsanları, bilgi ve becerilerini çeşitli amaçlar doğrultusunda kullanırlar:

- Kendi saldırı araçlarını geliştirmek.
- Hedef sistemde zafiyet tespit etmek.
- Tespit edilen zafiyet ile sisteme izinsiz erişim elde etmek.
- Sisteme zarar vermek veya güvenlik açıklarını kapatmak, sistemi korumak için kullanırlar.
- Bir hacker ihtiyaç duyduğunda sosyal mühendislik yapabilir



Hacker Türleri

Hackerlar, amaç ve faaliyetlerine göre farklı kategorilere ayrılırlar. Bu kategorizasyon, hackerların niyetlerini ve eylemlerinin yasal ve etik boyutlarını anlamamızı sağlar. Temel olarak üç ana hacker türü bulunmaktadır: Siyah Şapkalı Hacker, Gri Şapkalı Hacker ve Beyaz Şapkalı Hacker. Bu sınıflandırma, siber güvenlik dünyasındaki farklı rolleri ve yaklaşımları ortaya koymaktadır



Siyah Şapkalı Hacker (Black Hat Hacker)

Siyah Şapkalı Hackerlar, zarar vermek ve maddi kazanç sağlamak amacıyla sistemlere izinsiz giren kötü niyetli bilgisayar korsanlarıdır. Bu kişiler, sistemdeki bilgileri çalabilir, değiştirebilir veya silebilir, ayrıca sistemlere erişimi engelleyebilirler. Amacı, ele geçirdiği sistemleri kendi istekleri doğrultusunda kullanmaktır. Siyah şapkalı hackerlar, bilişim sistemlerinde zafiyetleri tespit edip bunları kötü niyetli eylemler için kullanırlar



Gri Şapkalı Hacker (Grey Hat Hacker)

Gri Şapkalı Hackerlar, merak ve kendi amaçları doğrultusunda sistemlerin güvenlik açıklarını tespit ederek sistemlere izinsiz giren bilgisayar korsanlarıdır. Bu kişiler, bazı durumlarda sisteme zarar verebilirken, bazı durumlarda ise sisteme zarar vermeyip güvenlik açığının kapatılmasına destek olabilirler. Bu nedenle, gri şapkalı hackerlar bazen siyah şapkalı, bazen de beyaz şapkalı hacker gibi davranabilirler. Sisteme izinsiz giriş yapma eylemleri onları siyah şapkalı hackerlara yaklaştırsa da, güvenlik açığını bildirme niyetleri beyaz şapkalı hackerların davranışlarına benzer



Beyaz Şapkalı Hacker (White Hat Hacker)

Beyaz Şapkalı Hackerlar, bilgisayar ve ağ sistemlerinin güvenliğini sağlamak amacıyla güvenlik açıklarını tespit edip kapatmaya çalışan, saldırıları önleyen iyi niyetli ve etik değerlere sahip bilgisayar korsanlarıdır. Bu kişiler, şahıs ve kurumlara zarar vermeyi düşünmezler. Hatta kurumların bilgisi dahilinde güvenlik açıklarını tespit edip kurumlara bildirirler. Kurumlara sağladıkları destek karşılığında maddi kazanç elde edebilir ve kurumlarda siber güvenlik personeli olarak görev alabilirler. Etik hackerlar olarak bilinirler ve faaliyetlerini izin alarak gerçekleştirirler



Etik Kavramının Temelleri

Siber Güvenliğe Giriş

Etik Kavramının Temelleri

Etik kavramı, insanın davranış biçimini ahlaksal açıdan inceleyen, düzenleyen bir disiplin olarak tanımlanmaktadır. Etik; insanların doğruyla yanlışı, iyiyle kötüyü, haklı ile haksızı ayırt ederek ahlaklı davranışlar sergilemesini sağlayan bir felsefe dalıdır. Günümüzde etik, daha çok çeşitli meslek kolları arasında tarafların uyması veya kaçınması gereken davranışlar bütünü olarak ifade edilmektedir. Etik ilkesine uymayan eylemler, toplumda güven eksikliğine ve sorunlara neden olarak uzun vadede olumsuz sonuçlara yol açabilir



Bilişim Etiği ve Önemi

Bilişim teknolojilerinin gelişmesi, bilişim araçlarının diğer meslek dallarında kullanılması, iletişim araçlarının insan davranış biçimini değiştirmesi gibi etkenler, etik kavramından bilişim etiği kavramının doğmasını zorunlu kılmıştır. Bilişim etiği; bilgisayar, ağ ve internetin kullanımı sırasında uyulması gereken, bilgi toplumu tarafından kabul gören, yazılı veya yazılı olmayan kurallar bütünüdür. Bu kurallara uyulduğunda bilişim ortamları daha güvenilir hâle gelir. İnternet ve sosyal medya gibi platformların yaygınlaşmasıyla ortaya çıkan bilgi kirliliği, siber zorbalık, veri ihlalleri gibi etik dışı uygulamalar, bilişim etiğinin önemini vurgular



Bilişim Etiğinin Amacı ve Kapsamı

Bilişim etiği, teknoloji geliştiricilerinin, karar alıcıların ve kullanıcıların bilinçli bir şekilde hareket etmesini teşvik eder. Bilişim etiği, bilgi gizliliğine önem verir. Günümüzde teknolojik gelişmelerin etkisiyle internet ortamında bulunan veri boyutu sürekli artış göstermekte ve bu veriler kötü niyetli kullanıcıların hedefi olabilmektedir. Bu yüzden bilgi teknolojileri ve bilişim araçları kullanıcılarının, bilişim etiği çerçevesinde davranmalarının sağlanması için kişisel, kurumsal ve hassas verilere yetkisiz erişim, izinsiz paylaşım, bilgi gizliliğinin ihlali gibi kötü niyetli davranışlardan uzak durması konusunda eğitilmeleri gerekir. Bilişim etiği, teknoloji kullanımının insan haklarına ve değerlerine saygılı olmasını sağlar



Siber Güvenlik Uzmanlarının Ahlaki Sorumlulukları

Bilgi güvenliği uzmanları, kurumdaki bilgi güvenliğini sağlamakla görevli kişilerdir ve mesleki sorumluluğun ahlaki bir boyutu bulunmaktadır. Bilgi güvenliği uzmanlarının faaliyetleri kurum çalışanlarını, müşterilerini ve paydaşlarını ahlaki açıdan önemli zararlardan korumalıdır. Aksi hâlde geri dönüşü olmayan durum ve hak ihlalleriyle karşılaşılır, bu nedenle bilgi güvenliği uzmanlarının kararları son derece kritiktir. Bazı ahlaki sorumlulukları şunlardır:

- Mesleki faaliyetlerini dürüstlük, doğruluk, adalet, vicdan, onur, sorumluluk, ahlak, nezaket, saygı, titizlik, tarafsızlık vb. etik ilkeler ve yürürlükteki yasalar çerçevesinde gerçekleştirmek.
- Kurumların güncel uygulamaları ve standartları kullanımını teşvik etmek.
- Çıkar çatışması oluşturabilecek faaliyetlerden kaçınmak.
- Mesleki faaliyetler sırasında karşılaşılan özel veya diğer hassas bilgilerin gizliliğini korumak



Siber Güvenlik Uzmanlarının Ahlaki Sorumlulukları

Siber güvenlik uzmanlarının ahlaki sorumlulukları, sadece teknik becerilerle sınırlı değildir, aynı zamanda yüksek etik standartları da içerir. Bu sorumluluklar, dijital ortamda güven ve bütünlüğün sağlanması için temel teşkil eder. Diğer ahlaki sorumlulukları şunlardır:

- Menfaat sağlamaya çalışmaktan uzak durmak.
- Kurum ve paydaşlarına, müşterilerine zarar verecek faaliyetlerden kaçınmak.
- Mesleki faaliyetleri eksiksiz olarak yerine getirmek.
- Bilgi güvenliği mesleğinin itibarını zedeleyecek faaliyetlerden uzak durmak.
- Fikrî mülkiyet ve mahremiyet haklarının ihlalinden kaçınmak.
- Bilginin erişilebilirliğine ilişkin uzun süreli veya kasıtlı tavizlerde bulunmamak.
- Kurum çalışanlarını, müşterilerini ve paydaşlarını sistem değişiklikleri hakkında bilgilendirmek.
- Kurum ve müşterilere ait hassas verileri saldırılardan korumak için güvenlik önlemleri almak.
- Bilgi güvenliği ekibiyle iş birliği içinde çalışmak.
- Tespit ettiği güvenlik açıklarını ve ihlalleri, uygun kanallar aracılığıyla yetkililere bildirmek.
- Sızma testi için izin ve yetki alarak yalnızca verilen izin ve yetki dâhilindeki işlemleri gerçekleştirmek

Bilgi Güvenliğinde Yasal Düzenlemelere Giriş

Bilgi işlem teknolojilerinin gelişmesi, yeni program ve web, mobil, sosyal ağ gibi uygulamaların oluşturulması ve veri miktarının çoğalması ile bilgi sistemlerine yönelik saldırılar artış göstermiştir. Saldırganları caydırmak, bilgi sistemlerinin ve verilerin kötü amaçla kullanımını önlemek için mevcut yasaların uygulanması gerektiğine karar verilmiştir. Mevcut yasaların bilgi güvenliği uygulaması ile ilgili problemleri gidermekte yetersiz kalması, yeni yasaları ve hukuki düzenlemeleri zorunlu kılmıştır. Bu gelişmeler, bilişim hukuku dalının ortaya çıkmasına neden olmuştur



Türkiye'deki Bilgi Güvenliği Yasal Düzenlemeleri

Ülkemizde bilgilerin gizliliğini korumak ve güvence altına alınmasını sağlamak için gerekli yasal düzenlemeler bilişim hukuku çatısı altında hazırlanmaktadır. İhtiyaçlar doğrultusunda bilişim sektöründe yasal düzenlemeler devam etmektedir. Bu yasal düzenlemeleri ihlal eden kişiler, başka bir deyişle suç işleyenler, kanunlar çerçevesinde cezalandırılır. Türkiye'de bilgi güvenliği uygulaması ile ilgili yürürlükte olan bazı yasal düzenlemeler şunlardır:

- Türkiye Cumhuriyeti Anayasası.
- 5237 sayılı Türk Ceza Kanunu.
- 6698 sayılı Kişisel Verilerin Korunması Kanunu.
- 5846 sayılı Fikir ve Sanat Eserleri Kanunu



Türkiye'deki Bilgi Güvenliği Yasal Düzenlemeleri

Bilişim sektöründeki hızlı değişimler, yasal düzenlemelerin de sürekli güncellenmesini gerektirmektedir. Bu süreç, dijital güvenliği sağlamak adına atılan önemli adımlardan biridir. Türkiye'de bilgi güvenliği ile ilgili yürürlükte olan diğer yasal düzenlemeler şunlardır:

- 5809 sayılı Elektronik Haberleşme Kanunu.
- 5651 sayılı İnternet Ortamında Yapılan Yayınların Düzenlenmesi ve Bu Yayınlar Yoluyla İşlenen Suçlarla Mücadele Edilmesi Hakkında Kanun.
- Elektronik Haberleşme Sektöründe Kişisel Verilerin İşlenmesi ve Gizliliğin Korunmasına İlişkin Yönetmelik.
- Elektronik Haberleşme Sektöründe Şebeke ve Bilgi Güvenliği Yönetmeliği.
- 5070 sayılı Elektronik İmza Kanunu.
- Avrupa Konseyi bünyesinde hazırlanan ve ülkemizin de taraf olduğu Sanal Ortamda İşlenen Suçlar Sözleşmesi (Council of Europe: Convention on Cybercrime).
- 06.07.2019 tarihli ve 30823 sayılı Bilgi ve İletişim Güvenliği Tedbirleri konulu Cumhurbaşkanlığı Genelgesi.
- 10.07.2020 tarihli Türkiye Cumhuriyeti Cumhurbaşkanlığı Dijital Dönüşüm Ofisi tarafından yayımlanan Bilgi ve İletişim Güvenliği Rehberi.
- 10.10.2021 tarihli Türkiye Cumhuriyeti Cumhurbaşkanlığı Dijital Dönüşüm Ofisi tarafından yayımlanan Bilgi ve İletişim Güvenliği Denetim Rehberi



Bilgi Güvenliđi Uygulamalarında Karşılaşılan Yasal Problemler

Kurum ve kişiler, yasal düzenlemeleri takip edip onlara uymakla yükümlüdürler. Gerekli önlemler alınmadığında veya alınan önlemler yetersiz kaldığında birçok sorun ile karşılaşılır. Bilgi güvenliđi uygulamalarında karşılaşılan ihlallerin her biri yasal bir problem teşkil eder. Bu yasal problemlerden bazıları şunlardır:

- Fikrî mülkiyet hırsızlığı.
- İş süreçlerine ilişkin özel bilgilerin istismarı.
- Veri gizliliğinin ihlali.
- Veri hırsızlığı.
- Hassas verileri yok etme.
- Bilişim teknolojilerine yönelik risk ve zararlar.
- Kurum itibarına yönelik risk ve zararlar.
- Bilgi sistemine yetkisiz erişim



Bilgi Güvenliği Uygulamalarında Karşılaşılan Yasal Problemler

Dijital ortamda yaşanan gelişmeler, birçok yeni yasal problemi de beraberinde getirmektedir. Bu problemlerin önlenmesi ve çözülmesi için sürekli yeni yaklaşımlar geliştirilmektedir. Karşılaşılan diğer yasal problemler şunlardır:

- Bilgi sistemine erişimi engelleme.
- Bilgi sistemini bozma.
- Tersine mühendislik ile telif hakkı ve patent ihlali.
- Lisans ihlali.
- Yetkisiz veri iletimi.
- Patentlerin yasa dışı kullanımı.
- Telif hakkıyla korunan elektronik materyalin yasa dışı kullanımı.
- Telif hakkıyla korunan materyallerin yasa dışı erişimi.
- Kurum personelinin kişisel bilgilerinin istismarı



Bilgi Güvenliđi Uygulamalarında Karşılaşılan Yasal Problemler

Yasal düzenlemeler ve problemler, siber güvenlik alanının dinamik doğasının bir yansımasıdır. Sürekli değişen tehditler, yeni yasal zorlukları da beraberinde getirir. Son olarak, karşılaşılan diğer önemli yasal problemler:

- Kurum müşterisinin kişisel ve finansal bilgilerinin istismarı.
- Hasta tıbbi kayıtlarının ifşası.
- Yazılım kaynak kodunun yasa dışı kullanımı.
- Güvenlik protokollerini atlatma.
- Elektronik ticaret uygulamasını kısıtlama.
- İnternet bankacılığı işlemlerini aksatma.
- Çekiliş veya şans oyunu sonucunu değiştirme.
- Finansal yatırım uygulamalarında kur verilerini değiştirme



Telif Hakları (Copyright)

Telif (Copyright); kişinin her türlü fikrî emeği ile meydana getirdiği bilgi, düşünce, sanat eseri ve ürünün kullanılması, kopyalanması ile ilgili hukuken sağlanan haklardır. Telif hakkı; bilim, edebiyat, sinema, müzik, güzel sanat eserleri ile bilgisayar yazılımlarının tümüne koruma sağlamaktadır. Telif hakkının doğması için tescile gerek yoktur. Fikir ve sanat eserleri üzerindeki haklar, eserin üretilmesiyle birlikte doğar. Ülkemizde telif hakları, 5846 sayılı Fikir ve Sanat Eserleri Kanunu ile güvence altına alınmıştır. Telif hakkı bulunan bilginin, ürünün, sanat eserinin izinsiz bir şekilde kullanılması, dijital ortamlarda yayımlanması, kopyalanması 5846 sayılı Fikir ve Sanat Eserleri Kanunu ile yasaklanmıştır. Ayrıca telif hakkı ihlali durumunda cezai sorumluluk ortaya çıkar



Dijital Ortamda Telif Hakları

Telif hakkı bulunan eserlerin dijital ortamlarda paylaşılması, kopyalarının çoğaltılması, benzerlerinin üretilmesi gibi problemlerin yaygınlaşması, Fikir ve Sanat Eserleri Kanunu'nun bilişim teknolojileri alanına uygulanmasını gerekli kılmıştır. Telif hakları, eser sahiplerinin eserlerini koruyarak adil rekabeti sağlar ve onlara eserlerini ticari olarak değerlendirme imkânı verir. Telif hakları hakkında detaylı bilgi almak için www.telifhaklari.gov.tr web sitesi ziyaret edilebilir



6698 Sayılı Kişisel Verilerin Korunması Kanunu (KVKK) Amacı

İletişim teknolojilerinin gelişmesi ve internet kullanımının artmasıyla kişisel veriler kolayca paylaşılabılır ve geniş kitlelere yayılabilir hâle gelmiştir. Veri güvenliğinin çok önemli olduğu günümüzde kişisel verilerin korunması bir zorunluluktur. Ülkemizde kişisel verilerin korunması amacıyla 6698 sayılı Kişisel Verilerin Korunması Kanunu, 7 Nisan 2016 tarihinde yürürlüğe girmiştir. Kanun'un amacı, "kişisel verilerin işlenmesinde başta özel hayatın gizliliği olmak üzere kişilerin temel hak ve özgürlüklerini korumak ve kişisel verileri işleyen gerçek ve tüzel kişilerin yükümlülükleri ile uyacakları usul ve esasları düzenlemektir"



Kişisel Veri ve Kişisel Verileri Koruma Kurumu

Kimliği belirli veya belirlenebilir gerçek kişiye ilişkin her türlü veri, kişisel veri olarak ifade edilir. Örneğin; kişinin adı soyadı, doğum tarihi, telefon numarası, ikametgâh adresi, kredi kartı son kullanım tarihi, öğrenim durumu, aşı bilgileri kişisel veri olarak nitelendirilir. Ancak bir kuruma ait adres, vergi numarası, e-posta adresi gibi bilgiler tüzel kişiliğe aittir ve kişisel veri olarak nitelendirilemez. 6698 sayılı Kişisel Verilerin Korunması Kanunu'nun yüklediği görevleri yerine getirmek üzere Kişisel Verileri Koruma Kurumu (KVKK) kurulmuştur. Kanun hakkında detaylı bilgi sahibi olmak için www.kvkk.gov.tr web sitesi ziyaret edilebilir



KVKK Kapsamındaki Temel Tanımlar

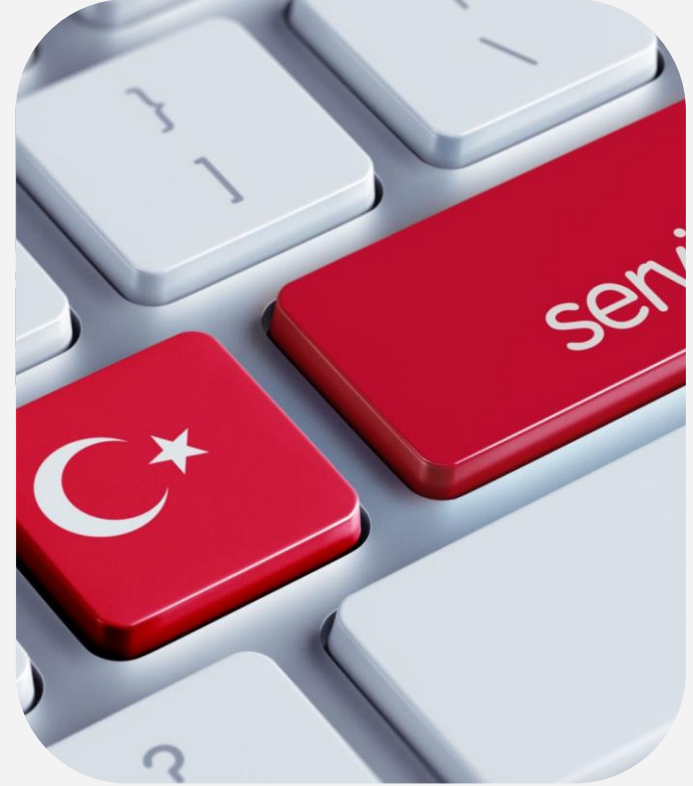
6698 sayılı Kişisel Verilerin Korunması Kanunu'nda yer alan bazı temel tanımlar, veri koruma süreçlerini anlamak için kritiktir:

- Açık rıza: Belirli bir konuya ilişkin, bilgilendirmeye dayanan ve özgür iradeyle açıklanan rızayı ifade eder.
- İlgili kişi: Kişisel verisi işlenen gerçek kişiyi tanımlar.
- Veri işleyen: Veri sorumlusunun verdiği yetkiye dayanarak onun adına kişisel verileri işleyen gerçek veya tüzel kişiyi belirtir.
- Veri sorumlusu: Kişisel verilerin işleme amaçlarını ve vasıtalarını belirleyen, veri kayıt sisteminin kurulmasından ve yönetilmesinden sorumlu olan gerçek veya tüzel kişidir.
- Kişisel verilerin işlenmesi: Kişisel verilerin tamamen veya kısmen otomatik olan ya da herhangi bir veri kayıt sisteminin parçası olmak kaydıyla otomatik olmayan yollarla elde edilmesi, kaydedilmesi, depolanması, muhafaza edilmesi, değiştirilmesi, yeniden düzenlenmesi, açıklanması, aktarılması, devralınması, elde edilebilir hâle getirilmesi, sınıflandırılması ya da kullanılmasının engellenmesi gibi veriler üzerinde gerçekleştirilen her türlü işlemi ifade eder



Güvenli Dijital Vatandaşlık Tanımı

Güvenli dijital vatandaşlık, bireylerin bilişim teknolojilerini ve interneti güvenli bir şekilde kullanmasını, etik ve sorumlu bir şekilde davranmasını, dijital dünyadaki tehlikelerden korunmasını sağlayan bir kavramdır. Siber vatandaşlık veya e-vatandaşlık olarak da adlandırılır. Günümüzde dijital teknolojilerin yaygın kullanımıyla birlikte bireylerin dijital ortamlarda bilinçli, dikkatli olması ve dijital güvenlik önlemlerini alması çok önemlidir. Dijital araçları doğru ve sorumlu bir şekilde kullanabilmek için eğitim ve farkındalık çalışmaları ile desteklenmesi gerekir



Güvenli Dijital Vatandaşlığın Temel Kavramları

Güvenli dijital vatandaşlık, çeşitli alt kavramları içerir ve bu kavramlar bireylerin dijital dünyadaki davranışlarını ve etkileşimlerini şekillendirir.

- **Dijital İletişim:** Bilgi ve iletişim teknolojilerinin kullanıldığı elektronik ortamlar aracılığıyla gerçekleştirilen iletişim sürecidir. İnternet, e-posta, sosyal ağlar, mesajlaşma, video konferans gibi dijital araçlar ve platformlar üzerinden veri iletilmesi, paylaşılması ve alınması sürecidir.
- **Dijital Erişim:** Bireylerin bilgisayar, akıllı telefon, tablet vb. teknolojik cihazları kullanabilme ve dijital ortamlara erişebilme becerisidir.
- **Dijital Okuryazarlık:** Bireylerin dijital ortamlardan elde ettiği, okuduğu her bilginin doğru olmayabileceğini değerlendirmesi ve bilgi kirliliğine dikkat ederek doğru, güvenilir kaynaklardan bilgiye ulaşabilmesidir.
- **Dijital Güvenlik:** Dijital vatandaşların güvenliklerine dikkat etmesini ve gerekli önlemleri almasını gerektirir. Örneğin şifre ve parolaların güçlü bir şekilde belirlenmesi, aynı şifre ve parolanın farklı platformlarda kullanılmaması, antivirüs programı kullanılması gibi tedbirler dijital güvenlik için dikkat edilmesi gereken hususlardan bazılarıdır.



Güvenli Dijital Vatandaşlığın Temel Kavramları

Dijital vatandaşlığın diğer önemli kavramları, etik davranışlardan yasalara ve kişisel sağlığa kadar geniş bir yelpazeyi kapsar.

- **Dijital Etik:** Dijital ortamlarda kullanıcılara saygılı olmayı ve empatik davranmayı gerekli kılan bir kavramdır. İnternet ortamında düşünce ve ifade özgürlüğüne saygı göstermek, başkalarını rahatsız etmemek, hakaret etmemek, zarar verici içerikler paylaşmamak vb. dijital etik davranışlara örnek gösterilebilir.
- **Dijital Haklar ve Sorumluluklar:** Dijital dünyada bireylerin ve kullanıcıların sahip olduğu hakları ve bu hakları kullanırken uyması gereken sorumlulukları içeren kavramlardır.
- **Dijital Kanun:** İnternet kullanımı esnasında suç olabilecek ihlallerin vatandaşlar tarafından bilinmesi ve bu ihlallere dikkat edilmesidir. Dijital vatandaşların görevi; sosyal medya ortamlarında zorbalık, şantaj, itibar zedeleme gibi siber suçların kanun önünde cezai yaptırımlarının bulunduğu bilincinde olmak ve bu konuda diğer kullanıcıları bilinçlendirmektir.
- **Dijital Sağlık:** Bilgisayar, akıllı telefon, tablet gibi internete erişim sağlayan cihazların uzun süreli kullanımından dolayı fiziksel ve ruhsal sorunlar ortaya çıkabilir. Bu nedenle cihazların uzun süreli kullanımından kaçınmak gerekir.
- **Dijital Ticaret:** Ticari işlemlerin dijital ortamlara taşınmasıyla birlikte bankacılık, alışveriş gibi işlemler bu dijital ortamlardan gerçekleştirilmeye başlanmıştır. Dijital vatandaş, ticari işlemler gerçekleştirirken doğru ve güvenilir kaynakları tercih etmeli, dolandırıcılık ve fidye isteme gibi kötü niyetli tuzaklardan kendini koruyabilmelidir.



İnternet Gizliliği Tanımı

İnternet gizliliği; kişisel verilerin internet üzerinden depolanması, kullanılması, görüntülenmesi ve üçüncü şahıslarla paylaşılması ile ilgili kişisel gizlilik hakkını ifade eder. Bilgi gizliliğinin bir parçası olan internet gizliliği; kişisel verilerin, kişisel seçimlerin ve iletişimin korunması amacını taşır



İnternet Gizliliğinin İhlali ve Riskler

Kişisel verilerin bazı internet sitelerinde toplanması ve yayınlanması gizliliğin ihlaline neden olur. İnternet siteleri, çoğunlukla hamilinin açık rızası olmadan kamuya açık hâle getirilen her türlü kişisel veriyi içerir. Bu kişisel veriler; kişinin telefon numarası ve adresi, üye olduğu kuruluşlar, adının geçtiği çevrimiçi dergi ve gazeteler, görüntüsünün bulunduğu resim ve video klipler olabilir. İnternet sitelerinde yayınlanan bu veriler arama motorları ile kolaylıkla bulunabilir. İnternet kullanıcılarının üçüncü şahıslar tarafından çevrimiçi olarak izlenmesi, internet gizliliği açısından büyük risk oluşturur. Çerez (cookie) dosyaları, kullanıcının web kullanım profili ve casus yazılımlar önemli riskler arasında yer alır. Bu riskler, üçüncü şahısların internetten bilgi toplama eylemini gerçekleştirmesine yardımcı olur. Örneğin sosyal ağına üye olurken girilen kişisel verilerin veya e-ticaret sitesinden alışveriş yaparken girilen kredi kartı bilgilerinin üçüncü şahıslar tarafından elde edilmesi internetin gizliliği ile ilgilidir. Bu nedenle internet üzerinden gerçekleştirilecek her bir eylemde çok dikkatli olunmalıdır.



İnternet Gizliliğinin İhlali ve Riskler

Kişisel verilerin bazı internet sitelerinde toplanması ve yayınlanması gizliliğin ihlaline neden olur. İnternet siteleri, çoğunlukla hamilinin açık rızası olmadan kamuya açık hâle getirilen her türlü kişisel veriyi içerir. Bu kişisel veriler; kişinin telefon numarası ve adresi, üye olduğu kuruluşlar, adının geçtiği çevrimiçi dergi ve gazeteler, görüntüsünün bulunduğu resim ve video klipler olabilir. İnternet sitelerinde yayınlanan bu veriler arama motorları ile kolaylıkla bulunabilir. İnternet kullanıcılarının üçüncü şahıslar tarafından çevrimiçi olarak izlenmesi, internet gizliliği açısından büyük risk oluşturur. Çerez (cookie) dosyaları, kullanıcının web kullanım profili ve casus yazılımlar önemli riskler arasında yer alır. Bu riskler, üçüncü şahısların internetten bilgi toplama eylemini gerçekleştirmesine yardımcı olur. Örneğin sosyal ağına üye olurken girilen kişisel verilerin veya e-ticaret sitesinden alışveriş yaparken girilen kredi kartı bilgilerinin üçüncü şahıslar tarafından elde edilmesi internetin gizliliği ile ilgilidir. Bu nedenle internet üzerinden gerçekleştirilecek her bir eylemde çok dikkatli olunmalıdır.



Bilgi Güvenliđi Unsurları: CIA Üçlüsü

Bilgi, verilerin anlam ve değeri kazanmış hâlidir. Bilgi güvenliđi; kişisel veya kurumsal düzeydeki her tür bilginin yetkisiz şekilde elde edilmesini, kullanılmasını, değıştirilmesini, silinmesini, çalınmasını, ifşa edilmesini, el değıştirmesini ve zarar görmesini engellemek amacıyla alınan tedbirlerdir. Bilgi güvenliđi; **gizlilik** (confidentiality), **bütünlük** (integrity), **erişilebilirlik** (availability) olmak üzere üç temel unsurdan oluşur. Bilgi güvenliđi unsurlarına kısaca CIA üçlüsü adı verilir. Bilgi güvenliđi unsurlarından herhangi birinin zarar görmesi durumunda güvenlik zafiyeti ortaya çıkar



Gizlilik (Confidentiality)

Gizlilik, bilginin yetkisiz kişilerin eline geçmesinin engellenmesidir. Bilgi, yetkisiz kişiler tarafından elde edilirse gizlilik unsuru ihlal edilmiş olur. Bu, bilginin yalnızca yetkili kişiler tarafından erişilebilir olması gerektiği anlamına gelir. Örnekler:

- Sosyal ağ, e-posta veya internet bankacılığı hesap bilgilerinin saldırganın eline geçmesi gizlilik unsurunun zarar görmesine neden olur.
- Kişisel sağlık kayıtları veya finansal veriler gibi hassas bilgilerin yetkisiz ifşası gizlilik ihlalidir.



Bütünlük (Integrity)

Bütünlük, bilginin yetkisiz kişiler tarafından bozulmasının, değiştirilmesinin veya silinmesinin engellenmesidir. Bilginin doğru, tam ve güvenilir olması gerektiğini vurgular. Örnekler:

- Saldırgan tarafından web sayfasındaki bilgilerin değiştirilmesi veya veri tabanına yeni bilgilerin eklenmesi bütünlük unsurunun zarar görmesine neden olur.
- Bir sözleşmedeki rakamların veya maddelerin yetkisiz kişilerce değiştirilmesi de bütünlük ihlalidir.



Erişilebilirlik (Availability)

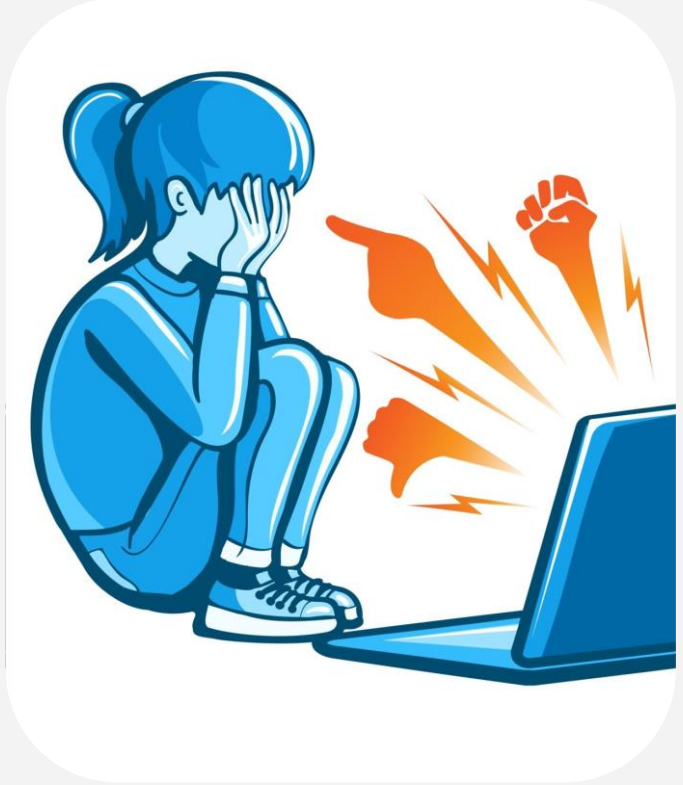
Erişilebilirlik, bilginin yetkili kişiler tarafından sürekli erişilebilir ve kullanılabilir durumda olmasıdır. Bilginin veya bilgi sistemlerinin, ihtiyaç duyulduğu anda hizmet vermeye devam etmesi esastır. Örnekler:

- Saldırganın bir web sayfasına veya veri tabanı sunucusuna erişimi engelleyerek hizmeti aksatması, erişilebilirlik unsurunun zarar görmesine neden olur.
- Hizmet Reddi (DoS) saldırıları, sunucuların aşırı yüklenerek meşru kullanıcılara hizmet veremez hâle gelmesine yol açarak erişilebilirliği ihlal eder



Siber Zorbalık (Cyberbullying)

Siber zorbalık; dijital ortamlarda kişilere karşı saldırganlık içeren, tehdit edici, rahatsız edici veya zarar verici davranışları ifade eder. İnternet, sosyal ağ ortamları, e-posta, anlık mesajlaşma gibi dijital iletişim araçları üzerinden gerçekleştirilen siber zorbalık, fiziksel temas olmaksızın yapılan bir dijital saldırı türüdür. Bu saldırıyı gerçekleştirene zorba, saldırıya maruz kalan bireye ise kurban denir. Siber zorbalığa maruz kalan birey, duygusal ve fiziksel olarak etkilenebilir ve bu etkiler uzun süre devam edebilir



Siber Zorbalık Davranışları ve Önlemler

Siber zorbalık, çeşitli şekillerde ortaya çıkabilir ve kurbanlar üzerinde derin etkiler bırakabilir. Siber zorbalık davranışları şunlardır:

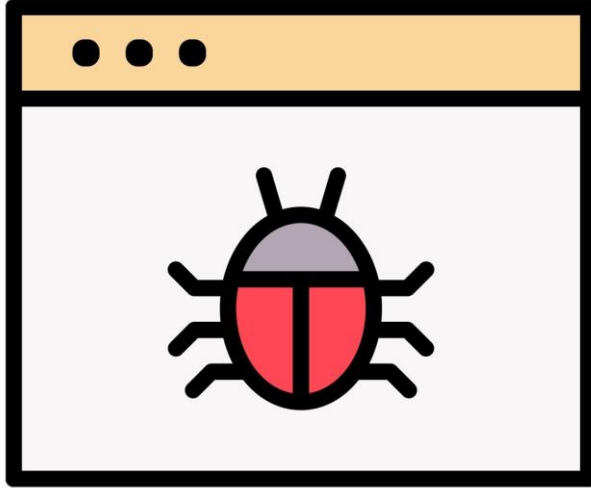
- Sosyal ağ ortamlarından kötü niyetli mesajlar yazmak.
- Tehdit etmek ve korkutmak.
- Birey hakkında gerçek olmayan bilgiler yaymak.
- Utanç verici içerik ve resimlerle kişiyi hedef almak.
- Kişiye özel bilgileri izinsiz paylaşmak.
- Sosyal ağ ortamlarına erişim sağlamak için kullanıcı adı ve şifresini paylaşmaya zorlamak.
- Ele geçirilmiş sosyal ağ hesabı ile başkalarını hedef almak. Siber zorbalığa karşı kurbanlar tarafından alınacak önlemler şunlardır:
- Öncelikle sakın olunmalı ve zorba ile kesinlikle temas kurulmamalıdır.
- Zorba, dijital ve sosyal ağ ortamlarından engellenmelidir.
- Siber zorbalığa maruz kalan birey, bu durumu bir aile büyüğüne, öğretmenine veya yardım edebilecek bir yakınına mutlaka bildirmelidir.
- Siber zorbalık ile ilgili kanıtlar (mesajlar, yorumlar, resimler vb.) ekran görüntüsü alınarak saklanmalıdır.
- Kanıtlarla birlikte yetkili birimlere müracaat edilmelidir.

Zararlı Yazılımlar

Zararlı yazılım (Malware); bilgisayar ve ağ sistemlerine zarar vermek, sistemlere sızmak, sistemlerin işleyişini engellemek, kişisel verileri ele geçirmek, değiştirmek ve gerektiğinde şifrelemek için kullanılan kötü amaçlı programlar olarak tanımlanır. Zararlı yazılım saldırıları çoğunlukla son kullanıcı cihazlarına yapılır. Bu nedenle kullanıcıların zararlı yazılımlar hakkında bilgi sahibi olması son derece önemlidir. Zararlı yazılımlar son kullanıcı cihazlarına farklı yollarla bulaşabilir.



Zararlı Yazılım Türleri



Zararlı yazılımların sayısı ve türü her geçen gün artmaktadır. Zararlı yazılım türleri genellikle virüsler, solucanlar, Truva atları ve diğer kötü amaçlı programlar şeklinde sınıflandırılır.

Zararlı Yazılım Türleri

Virüs: Kendi kopyasını bir programa, bir dokümana veya .bat, .exe, .com uzantılı yürütülebilir bir dosyaya ekleyerek yayılan yazılıma bilgisayar virüsü denir. Bir bilgisayardan başka bir bilgisayara kolaylıkla bulaşır. Program veya dosyalara bulaşan virüsler, kullanıcı etkileşimi ile barındırdıkları zararlı kodları çalıştırır. Bu zararlı kodların gerçekleştireceği eylemler farklılık gösterebilir. Bu eylemler; kişisel verilerin çalınması, değiştirilmesi, silinmesi veya işletim sisteminin çalışmaz hâle gelmesi olabilir. Günümüzde virüsler daha çok haricî depolama birimleri, USB bellekler, web sayfaları ve e-posta ekleri ile bulaşır.



Zararlı Yazılım Türleri

Solucan (Worm): Bilgisayar solucanı kendini otomatik kopyalar ve hızla çoğalır. Solucan, ağ ve bilgisayar sistemlerinin güvenlik açıklarından yararlanarak yayılır. Virüslerin aksine solucanların yürütülebilir bir dosyaya eklenmesi, diğer programlara bulaşması ve kullanıcı etkileşimi ile çalıştırılması gerekmez. Solucanlar e-posta, FTP, HTTP ve P2P dosya paylaşım ağları ile sistemlere bulaşabilir. Ağın performansını, işletim sisteminin işleyişini olumsuz yönde etkiler. Kişisel verilerin çalınmasına, işletim sisteminde arka kapı açarak zombi ağı oluşturulmasına neden olabilir.



Zararlı Yazılım Türleri

Truva Atı (Trojan): Bu yazılım, zararsız bir program gibi görünür. Genellikle e-posta veya güvenilir olmayan web siteleri aracılığıyla sisteme bulaşır. Kullanıcının zararlı dosyayı kopyalamasıyla yayılır. Truva atı, eklendiği program dosyası çalıştırılınca kadar aktif hâle geçmez. Truva atı aktif olduktan sonra saldırgana son kullanıcı cihazı için tam kontrol ve yükseltilmiş ayrıcalıklar sunar, uzaktan erişim yetkisi verir. Saldırgana uzaktan erişim yetkisi verir. Uzaktan erişim sağlayan saldırgan, bilgisayardaki dosyaları kopyalama, silme ve değiştirme işlemlerini gerçekleştirebilir. Ayrıca internet bankacılığı parolalarını ve kredi kartı bilgilerini ele geçirebilir. Tespiti zor olan Truva atları; bilgisayarlara yeni zararlı yazılımlar indirme, DoS atakları ile web sunucularının hizmetlerini engelleme, açık portları saldırgana bildirme, ekran görüntülerinin kaydını alma gibi birçok farklı işlemi gerçekleştirir.



Zararlı Yazılım Türleri

Fidye Yazılımı (Ransomware): Bu yazılım, saldırganların e-postalar üzerinden kurbanlarına gönderdiği kötü amaçlı reklamlar aracılığı ile bulaşır. Fidye yazılımı, son kullanıcı cihazındaki verileri sadece saldırganın bildiği bir şifreleme anahtarı ile şifreler. Saldırgan, verilerin bulunduğu sistemi rehin alır. Kurban, fidye ödeyinceye kadar veriler kullanılamaz hâle gelir. Saldırgan, gizliliğini korumak için ödemenin kripto para ile yapılmasını kurbandan ister. Saldırgan, kurban ödemeyi gerçekleştirdiğinde şifreleme anahtarını gönderebilir. Fidye yazılımı, saldırganların en çok maddi kazanç sağladığı zararlı yazılım türüdür. Bu nedenle son yıllarda kişisel ve kurumsal kullanıcılara yönelik fidye yazılım saldırıları artmıştır.



Zararlı Yazılım Türleri

Casus Yazılım (Spyware): Bu yazılım, burun sokan yazılım (snoopware) olarak da adlandırılır. Bu yazılımların amacı, sistem üzerinde gizli kalarak kullanıcı hakkında bilgi toplamaktır. Casus yazılımlar ile kullanıcı alışkanlıkları, kullanıcının ziyaret ettiği web sayfaları, kimlik bilgileri, kredi kartı bilgileri, e-posta adresleri ve parolalar kötü niyetli kişilere gönderilir. Casus yazılımlar çoğunlukla yasal yazılımlar veya Truva atları aracılığı ile sistemlere bulaşır.



Zararlı Yazılım Türleri

Reklam Yazılımı (Adware): Bu yazılım, son kullanıcı cihazında ziyaret edilen web sayfalarını izleyerek kullanıcıya uygun reklamları görüntüler. Açılır pencereler ile görüntülenen reklamlar, rahatsız edici ve can sıkıcı boyuta ulaşabilir. Reklamlara tıklanması durumunda reklam yazılımını programlayan kişiler maddi kazanç elde edebilirler. Reklam yazılımları, bazı yazılım sürümleri veya casus yazılımlarla son kullanıcı cihazına bulaşır.



Zararlı Yazılım Türleri

Korku Yazılımı (Scareware): Dolandırıcılık yazılımıdır. Bu yazılım, kullanıcıda korku ve endişe oluşturmak için sosyal mühendisliği kullanır. Sahte mesajlar ile kullanıcıyı belirli eylemleri gerçekleştirmesi için yönlendirir. Bu eylemin amacı çoğunlukla kullanıcının sahte mesajlarla yönlendirildiği yazılımı satın alma ve ödeme işlemi yapmasını sağlamaktır.



Zararlı Yazılım Türleri

Tuş Tutucu (Keylogger): Bu yazılım, kullanıcının klavyeden bastığı her tuşu yakalar ve kaydeder. Bu kayıtları saldırgana gönderebilir. Kullanıcının kimlik bilgileri, kredi kartı bilgileri, parolaları ve diğer önemli kişisel bilgileri çalınabilir.



Zararlı Yazılım Türleri

Kök Kullanıcı Takımı (Rootkit): Bu yazılım, saldırganın bir sisteme ayrıcalıklı erişimine izin verir. Rootkitler işletim sisteminin çekirdeğine yerleşir. Bu nedenle anti-malware yazılımları tarafından tespit edilmesi zordur. Rootkitler sistemde gizliliğini korur. Saldırgan, ayrıcalık elde ettiği sistemde kullanıcıya fark ettirmeden yasal olmayan işlemler gerçekleştirebilir.



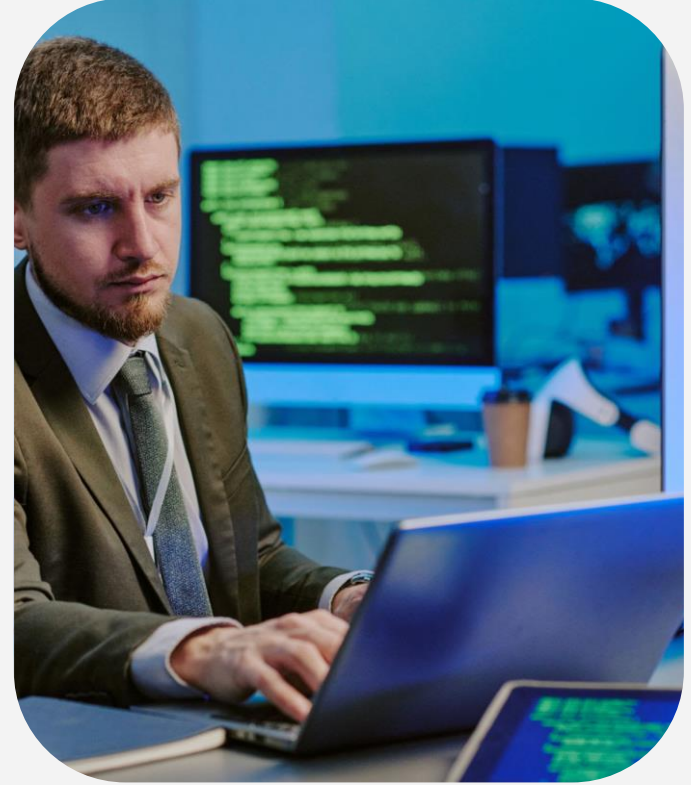
Zararlı Yazılım Türleri

Arka Kapı (Backdoor): Arka kapı, saldırganın bir sisteme erişmek için kimlik doğrulamasını atlamasına izin verir ve sisteme uzaktan erişmeyi sağlar. Sisteme erişen bilgisayar korsanları daha sonra aynı sisteme kolay erişim sağlayabilmek için arka kapıları kullanır. Saldırganlar sisteme arka kapı bırakabilmek için yeni bir port açma, yeni bir kullanıcı oluşturma eylemlerini gerçekleştirebilir. Ayrıca XSS, SQL Injection gibi zafiyetler de arka kapı olarak kullanılabilir.



Siber Güvenlik Profesyonellerinin Rolü

Siber güvenlik uzmanları, bilişim sistemlerini ve bilgi teknolojileri altyapısını siber saldırılara ve tehditlere karşı korumakla görevli kişilerdir. Bilgisayar korsanlarının, kötü niyetli yazılımların ve diğer siber tehditlerin neden olduğu güvenlik açıklarını tespit etmek, önlemek ve zafiyetlere karşı çözüm üretmek için çalışırlar. Bu uzmanlar, kurumdaki bilgi güvenliğini sağlamakla görevlidirler. Bilgi ve bilgi sistemlerinin tüm yönlerinin doğruluğunu, güvenilirliğini, kullanılabilirliğini, güvenliğini ve gizliliğini sağlamak için mesleki bir sorumluluğa sahiptirler



Siber Güvenlik Uzmanının Görev ve Sorumlulukları

Siber güvenlik uzmanlarının görev ve sorumlulukları, bir kurumun dijital varlıklarını korumak ve siber tehditlere karşı dirençli bir altyapı oluşturmak için hayati öneme sahiptir. Bu sorumluluklar, hem teknik hem de etik boyutları kapsar. Başlıca sorumluluklarından bazıları şunlardır:

- Siber güvenlik faaliyetlerini yasalara ve etik ilkelere uygun bir şekilde gerçekleştirmek.
- Kurum ve müşteriye ait fikri mülkiyet haklarının ve ticari sırların ihlalinin kaçınmak.
- Kurum ve kuruluşların güncel yazılım ve uygulamaları kullanmalarını teşvik etmek.
- Tespit ettiği güvenlik açıklarını ve ihlalleri, uygun kanallar aracılığıyla yetkililere bildirmek.
- Sızma testi için izin ve yetki alarak yalnızca verilen izin ve yetki dâhilindeki işlemleri gerçekleştirmek



Siber Güvenlik Uzmanının Görev ve Sorumlulukları

Siber güvenlik uzmanının sorumlulukları, sadece tehditleri önlemekle kalmaz, aynı zamanda bir ihlal durumunda doğru ve etkili müdahale yeteneğini de gerektirir. Diğer önemli sorumlulukları şunlardır:

- Mesleki faaliyet sırasında ortaya çıkan bilgilerin gizliliğini korumak.
- Yaptığı işlemlerin sonuçlarından sorumlu olmak.
- İş gereği edindiği verileri menfaati için kullanmamak.
- Verileri saldırılardan korumak için güvenlik önlemi almak.
- Bilgi güvenliği ekibiyle koordineli çalışmak.
- Kurum çalışanlarını, müşterilerini ve paydaşlarını sistem değişiklikleri hakkında bilgilendirmek.
- Bilgi güvenliği mesleğinin itibarını zedeleyecek faaliyetlerden uzak durmak



Siber Güvenlik Elemanının Özellikleri, Bilgi ve Becerileri

Siber güvenlik elemanları, karmaşık dijital tehditlerle mücadele etmek için belirli özelliklere, bilgi birikimine ve becerilere sahip olmalıdır. Kaynaklarda hackerlar için belirtilen üst düzey teknik bilgi ve beceriler, beyaz şapkalı hackerlar aracılığıyla siber güvenlik uzmanları için de geçerlidir. Siber güvenlik uzmanları, bilgi ve bilgi sistemlerinin tüm yönlerinin doğruluğunu, güvenilirliğini, kullanılabilirliğini, güvenliğini ve gizliliğini sağlamak için mesleki bir sorumluluğa sahiptir. Gerekli özellikler, bilgi ve beceriler, siber güvenlik uzmanının sorumluluklarından türetilir:

- Üst düzey teknik bilgi ve beceri: Sistem, ağ ve programlama alanlarında derinlemesine bilgiye sahip olmak.
- Analitik düşünme ve problem çözme yeteneği: Güvenlik açıklarını tespit etme, analiz etme ve çözüm üretme.
- Etik değerlere bağlılık: Mesleki faaliyetlerini dürüstlük, doğruluk, adalet ve tarafsızlık gibi etik ilkeler çerçevesinde gerçekleştirmek.
- Güncel gelişmeleri takip etme: Yeni tehditler ve saldırı yöntemleri hakkında sürekli bilgi sahibi olmak.
- İletişim ve iş birliği becerileri: Ekip içinde ve kurum paydaşlarıyla etkili iletişim kurabilme.
- Sorumluluk bilinci: Yaptığı işlemlerin sonuçlarından sorumlu olmak ve verileri korumak için gerekli önlemleri almak



Anahtar Kelimeler

Hafta 1 – Siber Güvenliğe Giriş



Anahtar Kelimeler

Adli Bilişim (Digital Forensics): Bilişim alanında işlenen suçlarla ilgili dijital ortamlardaki verilerin delil niteliği taşıyacak şekilde toplanması, incelenmesi ve raporlanması süreci.

Adware (Reklam Yazılımı): Kullanıcıya istenmeyen reklamlar gösteren, genellikle web sayfalarını izleyerek hedeflenen reklamları görüntüleyen zararlı yazılım.

APT (Advanced Persistent Threat – Gelişmiş Sürekli Tehdit): Uzun süre fark edilmeden kalarak hedefe yönelik veri çalmayı amaçlayan karmaşık ve sofistike siber saldırı.

Arka Kapı (Backdoor): Saldırganın bir sisteme kimlik doğrulamasını atlayarak gizlice erişmesini sağlayan yöntem veya yazılım.

Availability (Erişilebilirlik): Bilginin yetkili kişiler tarafından belirlenen zaman dilimlerinde sürekli erişilebilir ve kullanılabilir durumda olması. Bilgi güvenliğinin temel unsurlarından biridir.

Beyaz Şapkalı Hacker: Bilgisayar ve ağ sistemlerinin güvenliğini sağlamak, açıkları tespit edip kapatmak amacıyla etik ve iyi niyetli çalışan bilgisayar korsanı (etik hacker).

Bilişim Etiği: Bilgisayar, ağ ve internetin kullanımı sırasında uyulması gereken, bilgi toplumu tarafından kabul görmüş yazılı veya yazılı olmayan kurallar bütünü.

Bilgi Güvenliği: Kişisel veya kurumsal bilgilerin yetkisiz erişim, kullanım, değiştirme veya ifşadan korunması için alınan tedbirler.



Anahtar Kelimeler

Botnet Yazılımları: Saldırganların birçok bilgisayarı uzaktan kontrol etmesini sağlayan, genellikle DDoS saldırılarında kullanılan zararlı yazılımlar.

Brute Force Attack (Kaba Kuvvet Saldırısı): Bir kullanıcıya ait olası kullanıcı adı ve şifre kombinasyonlarını sistematik olarak deneyerek ele geçirmeye yönelik saldırı türü.

Casus Yazılım (Spyware): Sistem üzerinde gizli kalarak kullanıcı hakkında (web geçmişi, kimlik bilgileri, parolalar) bilgi toplayan yazılım.

CERT Secure Coding Standards: Yazılım geliştiricilerine güvenli kodlama uygulamaları konusunda rehberlik eden standartlar dizisi.

CIA Üçlüsü: Bilgi güvenliğinin temel unsurları olan Gizlilik (Confidentiality), Bütünlük (Integrity) ve Erişilebilirlik (Availability) kısaltması.

CIS Critical Security Controls: Siber saldırılara karşı dirençli sistemler oluşturmak için uygulanması gereken güvenlik kontrolleri listesi.

Confidentiality (Gizlilik): Bilginin yetkisiz kişilerin eline geçmesinin engellenmesi. Bilgi güvenliğinin temel unsurlarından biridir.



Anahtar Kelimeler

Copyright (Telif Hakkı): Kişinin fikri emeğiyle meydana getirdiği eserlerin (bilgi, düşünce, sanat eseri, yazılım) kullanımı ve kopyalanması üzerinde sahip olduğu yasal haklar.

Cyber Kill Chain (Siber Saldırı Yaşam Döngüsü): Bir siber saldırının keşiften hedefe yönelik eylemlere kadar izlediği planlı aşamalar dizisi.

Cyber Security (Siber Güvenlik): Dijital ortamlarda bilişim sistemlerini, ağları ve verileri siber tehditlere karşı koruma süreci.

DDoS (Distributed Denial of Service - Dağıtık Servis Dışı Bırakma): Zombi bilgisayarlar aracılığıyla çok sayıda bilgisayar kullanılarak bir sunucunun hizmet dışı bırakıldığı saldırı türü.

Delil Karartma: Suçluların yakalanmamak veya adli bilişim uzmanlarının işini zorlaştırmak için dijital delilleri silme, değiştirme veya gizleme gibi eylemleri.

Dijital Arşivleme: Fiziksel belgelerin taranarak veya OCR ile dijital formata dönüştürülüp belirli bir düzene göre saklanması.

Dijital Delil: Bilişim alanında işlenen suçlarla ilgili dijital ortamlardan elde edilen ve mahkemede kanıt niteliği taşıyan her türlü veri.



Anahtar Kelimeler

Dijital Etik: Dijital ortamlarda kullanıcılara saygılı ve empatik davranmayı gerektiren kavram.

Dijital Okuryazarlık: Bireylerin dijital ortamdaki bilgileri doğru değerlendirme ve güvenilir kaynaklara ulaşma becerisi.

Dinç Analiz Yöntemi (Dynamic Analysis): Yazılımın gerçek bir ortamda çalıştırılarak güvenlik açıklarının veya hatalı davranışların tespit edildiği analiz yöntemi.

DoS (Denial of Service - Servis Dışı Bırakma): Bir sunucunun geçici veya sürekli hizmet dışı bırakılarak kullanılamaz hâle getirilmesini hedefleyen siber saldırı.

Fidye Yazılımı (Ransomware): Kullanıcının verilerini şifreleyerek erişimi engelleyen ve fidyenin ödenmesi karşılığında şifrenin kaldırılmasını teklif eden zararlı yazılım.

Fiziksel Güvenlik: Bilişim sistemleri, ağlar, donanımlar ve verilerin bulunduğu fiziksel ortamların, hırsızlık, sabotaj, doğal afetler gibi fiziksel tehditlere karşı korunması için alınan önlemler.

Gri Şapkalı Hacker: Merak veya kendi amaçları doğrultusunda sistemlere izinsiz giren, bazen zarar veren, bazen de güvenlik açığının kapatılmasına destek olan hacker türü.



Anahtar Kelimeler

Güvenli Dijital Vatandaşlık: Bireylerin bilişim teknolojilerini ve interneti güvenli, etik ve sorumlu bir şekilde kullanması, dijital tehlikelerden korunması.

Hacker (Bilgisayar Korsanı): Bilgisayar ve haberleşme teknolojileri bilgisini gizli verilere ulaşmak, yasa dışı işlemler yapmak için kullanan kimse.

Hacking (Hackleme): Elektronik sistemlere zararlı yazılım bulaştırma, izinsiz erişim sağlama veya yetkisiz değişiklik yapma eylemleri.

Integrity (Bütünlük): Bilginin yetkisiz kişiler tarafından bozulmasının, değiştirilmesinin veya silinmesinin engellenmesi. Bilgi güvenliğinin temel unsurlarından biridir.

İnternet Gizliliği: Kişisel verilerin internet üzerinden depolanması, kullanılması ve paylaşılması ile ilgili kişisel gizlilik hakkı.

IoT (Nesnelerin İnterneti): İnternet bağlantısına sahip fiziksel cihazların, sensörlerin ve diğer nesnelerin birbirleriyle veri alışverişi yapabilmesi.

ISO 27001: Bilgi Güvenliği Yönetim Sistemi (BGYS) kurulması, uygulanması, sürdürülmesi ve sürekli iyileştirilmesi için gereksinimleri belirten uluslararası bir standart.



Anahtar Kelimeler

ISO 27002: ISO 27001 standardıyla birlikte kullanılan, bilgi güvenliği kontrollerini ve en iyi uygulama yönergelerini içeren bir standart.

ISO 27034: Uygulama güvenliği yönetimini ele alan, yazılım uygulamalarının tasarımından testine kadar güvenlik risklerini yönetmek için rehberlik sağlayan standart.

ISO/IEC 15408 (Common Criteria): Bilgi teknolojisi ürünlerinin ve sistemlerinin güvenlik özelliklerini değerlendirmek ve sertifikalandırmak için kullanılan uluslararası bir standart.

Keylogger (Tuş Tutucu): Kullanıcının klavyeden bastığı her tuşu kaydeden ve bu bilgileri saldırgana göndererek kişisel verileri çalabilen zararlı yazılım.

Kişisel Veri: Kimliği belirli veya belirlenebilir gerçek kişiye ilişkin her türlü bilgi (ad, soyadı, telefon numarası vb.).

Korku Yazılımı (Scareware): Kullanıcıda korku ve endişe oluşturarak sahte mesajlarla belirli eylemleri (örn. sahte yazılım satın alma) gerçekleştirmeye yönlendiren dolandırıcılık yazılımı.

Kriptografi: Bilgiyi güvenli bir şekilde saklamak ve iletmek için kullanılan şifreleme ve şifre çözme teknikleri.



Anahtar Kelimeler

Man In The Middle Attack (Ortadaki Adam Saldırısı): Aynı ağ içinde haberleşen iki bilgisayarın arasına girilerek ağ trafiğinin saldırgan üzerinden dinlenmesi.

Malware (Zararlı Yazılım): Bilgisayar ve ağ sistemlerine zarar vermek, sızmak, işleyişi engellemek veya veri çalmak için kullanılan kötü amaçlı programlar.

Metadata Analizi: Dijital dosyaların oluşturulma tarihi, yazar bilgisi gibi üst verilerinin incelenmesi.

NIST SP 800-53: ABD Ulusal Standartlar ve Teknoloji Enstitüsü tarafından federal bilgi sistemlerinin güvenliğini artırmak için geliştirilen bir rehber.

Ofansif Güvenlik: Bilişim sistemlerine sızma testi yapma ve zafiyetleri istismar etme tekniklerini kapsayan siber güvenlik alanı.

OWASP Top 10 (Open Web Application Security Project): Web uygulamalarının en yaygın güvenlik zafiyetlerini ve risklerini belirleyen uluslararası bir standartlar koleksiyonu.

PUKÖ Döngüsü (Planla-Uygula-Kontrol Et-Önlem Al): Bir yönetim sistemi (örn. BGYS) sürecinin sürekli iyileştirilmesi için kullanılan döngüsel yaklaşım.

Rootkit (Kök Kullanıcı Takımı): Saldırganın bir sisteme ayrıcalıklı erişimine izin veren, işletim sisteminin çekirdeğine yerleştiği için tespiti zor olan zararlı yazılım.



Anahtar Kelimeler

Siber Olaylara Müdahale Ekibi (SOME): Siber güvenlik olaylarını planlı bir şekilde ele alıp değerlendirebilen, hızlı ve etkin tepki verebilen uzmanlardan oluşan ekip.

Siber Zorbalık: Dijital ortamlarda kişilere karşı saldırganlık içeren, tehdit edici, rahatsız edici veya zarar verici davranışlar.

Siyah Şapkalı Hacker: Zarar vermek ve maddi kazanç sağlamak amacıyla sistemlere izinsiz giren kötü niyetli bilgisayar korsanı.

Sosyal Mühendislik: Bilişim sistemlerine saldırmak yerine insanları yanıltarak, manipüle ederek veya zafiyetlerinden faydalanarak bilgi toplama saldırı türü.

SQL Enjeksiyonu: Web uygulamalarındaki güvenlik açıkları kullanılarak SQL sorgularına müdahale edilerek veri tabanındaki kodları değiştirmeyi hedefleyen saldırı.

Statik Analiz Yöntemi: Yazılım kodunu çalıştırmadan analiz ederek potansiyel güvenlik açıklarını tespit etmeye çalışan yöntem.

Stuxnet: APT saldırılarına örnek gösterilen, İran'ın nükleer programını hedef alan karmaşık bir solucan yazılımı.

Truva Atı (Trojan): Zararsız bir program gibi görünen, ancak aktif olduktan sonra saldırganca arka kapı veya uzaktan erişim yetkisi veren zararlı yazılım.

Anahtar Kelimeler

Virüs: Kendi kopyasını bir programa veya yürütülebilir dosyaya ekleyerek yayılan, kullanıcı etkileşimi ile aktifleşen zararlı yazılım.

Worm (Solucan): Kendi kendine otomatik kopyalanan ve ağ güvenlik açıklarından yararlanarak hızla yayılan, kullanıcı etkileşimi gerektirmeyen zararlı yazılım.

Yazılım Güvenliği: Yazılımın saldırılara maruz kaldığında dahi işlevlerini doğru bir şekilde yerine getirmeye devam edebilmesi için güvenli bir şekilde tasarlanması, geliştirilmesi ve test edilmesi süreci.

Zero Day Attack (Sıfırıncı Gün Saldırısı): Henüz üreticisi tarafından bilinmeyen ve düzeltilmemiş bir güvenlik açığından yararlanılarak gerçekleştirilen siber saldırı.



Çalışma Soruları

Hafta 1 – Siber Güvenliğe Giriş



Çalışma Soruları

1. Hacker kavramının zaman içinde nasıl bir dönüşüm geçirdiğini açıklayınız.
2. Solucan (Worm) ile Virüs arasındaki temel fark nedir?
3. Bilgi güvenliğinin temel unsurlarını (CIA üçlüsü) kısaca açıklayınız.
4. Siyah Şapkalı Hacker ile Beyaz Şapkalı Hacker arasındaki temel farkı belirtiniz.
5. Fidyeye Yazılımı (Ransomware) saldırılarının ana amacı ve bulaşma yollarından birini açıklayınız.
6. Siber Güvenlik Uzmanlarının ahlaki sorumluluklarından iki tanesini örnek veriniz.
7. Kişisel Verilerin Korunması Kanunu (6698 sayılı) neden çıkarılmıştır?
8. Sıfırın Günü (Zero Day) saldırılarını tanımlayınız ve bunlara karşı alınabilecek bir önlemi belirtiniz.
9. Dijital arşivlemenin kurumsal kullanıma sağladığı iki avantajı açıklayınız.
10. Adli bilişim sürecinde dijital delillerin bütünlüğünü sağlamak için kullanılan önemli bir teknik nedir?



Deneme Soruları

Hafta 1 – Siber Güvenliğe Giriş



Çalışma Soruları

1. Siber güvenlik etiği ilkelerinin dijital dünyadaki bireyler ve kurumlar için önemi nedir? Bu ilkelerin ihlali durumunda ortaya çıkabilecek olası sonuçları tartışınız.
2. Zararlı yazılım türlerinden Truva Atı, Fidyeye Yazılımı ve Casus Yazılımı arasındaki temel farkları ve her birinin hedeflerini karşılaştırınız. Kurumsal bir ortamda bu tür yazılımlara karşı alınabilecek önleyici tedbirleri detaylandırınız.
3. Bilgi güvenliğinin üç temel unsuru olan gizlilik, bütünlük ve erişilebilirliği detaylıca açıklayınız. Her bir unsurun ihlal edildiği gerçek hayat senaryolarından örnekler veriniz ve bu ihlallerin etkilerini analiz ediniz.
4. Yazılım güvenliği ilkelerinden "gerek duyulan en az yetkiyi vermek", "savunma derinliği oluşturmak" ve "saldırı yüzey alanını azaltmak" kavramlarını açıklayarak, bu ilkelerin yazılım geliştirme sürecindeki uygulanışının siber saldırılara karşı dirençli yazılımlar oluşturmadaki rolünü değerlendiriniz.
5. Adli bilişimde dijital delil toplama ve muhafaza etme sürecinde dikkat edilmesi gereken hususları adım adım açıklayınız. Ayrıca, suçluların delil karartma tekniklerini ve adli bilişim uzmanlarının bu tekniklere karşı uyguladığı yöntemleri tartışınız.



ÖZET



Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

